Threat Analysis Report

รายงานวิเคราะห์ช่องโหว่การยกระดับสิทธิ์บน Windows Server 2025 ผ่านการใช้งาน dMSA (CVE-2025-53779)

22/10/2025

TLP:CLEAR

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ
๑๒๐ ชั้น ๗ อาคารซี ศูนย์ราชการเฉลิมพระเกียรติ ๘๐ พรรษา ๕ ธันวาคม ๒๕๕๐
ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพมหานคร ๑๐๒๑๐ อีเมล saraban@ncsa.or.th

สารบัญ

สารบัญ 2
บทสรุปสำหรับผู้บริหาร 3
การวิเคราะห์เชิงเทคนิค 4
Technique Tactics and Procedures (MITRE ATT&CK) 6
Indicator of Compromise (IOCs) 7
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ 8
อ้างอิง (References) 10

บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์ช่องโหว่ความปลอดภัยการยกระดับสิทธิ์บนระบบ Active Directory ของระบบปฏิบัติการ Windows Server 2025 ผ่านการใช้ประโยชน์ช่องโหว่บนฟีเจอร์ Delegated Managed Service Account (dMSA) ซึ่งสามารถที่จะสืบทอดสิทธิ์, กลุ่มและคีย์จากบัญชีแบบเดิม

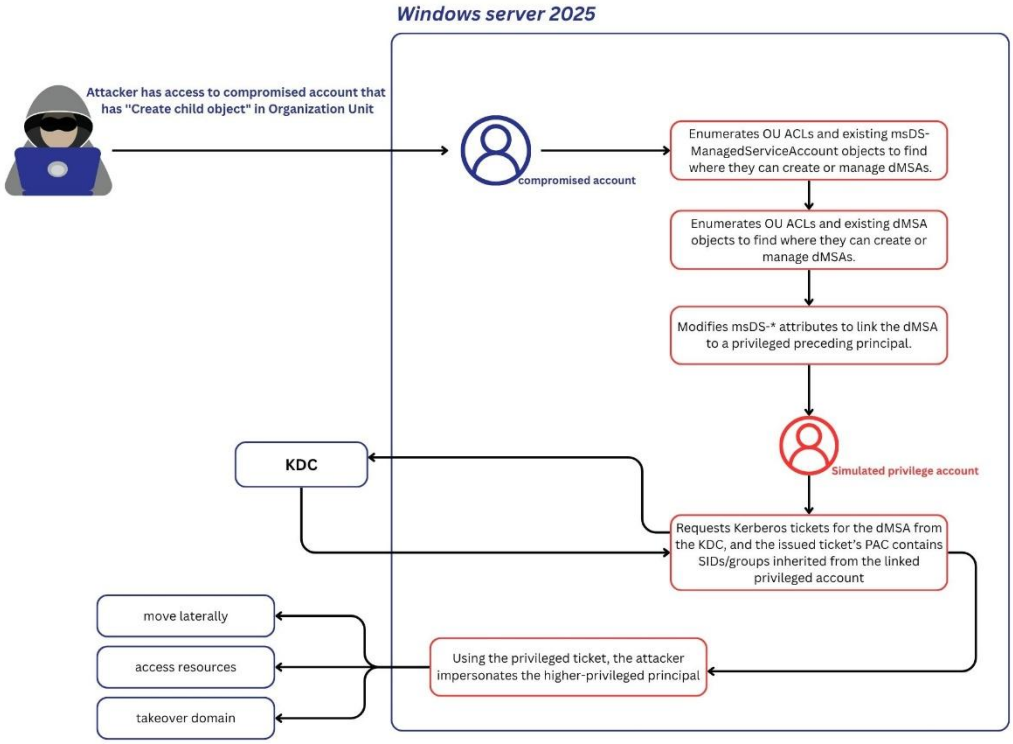
BadSuccessor เป็นช่องทางการยกระดับสิทธิ์ (privilege escalation) ที่ใช้การลักลอบผูก dMSA กับบัญชีที่เป็น preceding principal ผ่านการแก้ไข msDS-* attributes ซึ่งทำให้ผู้ไม่หวังดีที่มีสิทธิ์เพียงเล็กน้อยบน Organizational Unit สามารถขอ Kerberos tickets ที่มีสิทธิ์ระดับสูงได้

ในขณะนี้ทาง Microsoft ได้ทำการแก้ไขเป็นที่เรียบร้อยแล้วในเดือนสิงหาคม หากองค์กรยังไม่ได้มีการอัปเดต ควรเร่งให้มีการดำเนินการอัปเดต

การวิเคราะห์เชิงเทคนิค

Attack Flow

1. **Initial Access:** ผู้ไม่หวังดีได้บัญชีผู้ใช้ในโดเมน (จากการ phishing, credential reuse, หรือ lateral compromise) โดยไม่จำเป็นต้องเป็นสิทธิ์ของ Admin ขอเพียงแค่สิทธิ์ในการสร้าง Child objects บน Organizational Unit
2. **Reconnaissance / Enumeration:** ผู้ไม่หวังดีจะทำการ enumerate OU และ ACLs เพื่อหา OU สามารถใช้ Create child objects หรือสิทธิ์เฉพาะในการสร้าง dMSA ได้ พร้อมทั้งค้นหา existing msDS-ManagedServiceAccount objects และ preceding links เพื่อวางแผนในการเพิ่มระดับบัญชีต่อไป
3. **Create dMSA / Initiate migration:** ผู้ไม่หวังดีทำการสร้าง msDS-managedServiceAccount (dMSA) object บน OU ที่บัญชีนั้นมีสิทธิ์
4. **Abuse migration:** ในระหว่างและหลังกระบวนการ Migration นั้นผู้ไม่หวังดีจะทำการแก้ไข Attribute อย่าง msDS-ManagedAccountPrecededByLink หรือ msDS-GroupMSAMembership เพื่อผูก dMSA กับบัญชีที่จะรับสืบทอด (preceding principal) ที่ต้องการ เช่น built-in Administrator หรือ principal ที่มีสิทธิ์สูง
5. **Request Kerberos ticket (TGS/TGT) as dMSA:** ผู้ไม่หวังดีจะทำการ Request Kerberos ticket (TGS/TGT) ด้วย dMSA ที่สร้างขึ้นมาจาก Key Distribution Center (KDC) ซึ่ง Ticket นั้นจะมี PAC ซึ่งมีการระบุ SID และ Group ของบัญชีที่ไปทำการสืบทอดมา ทำให้ยืนยันได้ว่า dMSA นั้นได้เชื่อมต่อและสืบทอดสิทธิ์จากบัญชีที่ลิงค์แล้ว
6. **Impersonation / Lateral movement / Privilege escalation:** ด้วย Ticker ที่มี PAC ซึ่งมีสิทธิ์สูง ผู้ไม่หวังดีสามารถเข้าถึง resource อื่น เช่น file servers, DC management hosts, หรือทำ operations ใน AD ที่ต้องการสิทธิสูงขึ้นนำไปสู่ domain takeover



[แผนภาพการโจมตีช่องโหว่ CVE-2025-53779]

รายละเอียดช่องโหว่ (CVE-2025-53779):

ช่องโหว่เกิดจากฟีเจอร์ใหม่ของ Windows Server 2025 ที่เรียกว่า delegated Managed Service Accounts (dMSA) ซึ่งใช้ในการย้าย nonmanaged service account มาเป็น dMSA ในระบบใหม่ ซึ่งตัว dMSA นั้นสามารถที่จะสืบทอดสิทธิ์, กลุ่ม และคีย์ของบัญชีที่สืบทอดมาได้ด้วย ซึ่งทำให้ผู้ไม่หวังดีใช้ประโยชน์จากช่องโหว่นี้ร่วมกับบัญชีอื่น ๆ ที่ถูกโจมตีและมีสิทธิ์ในการสร้าง dMSA มาเพื่อใช้ในการสร้างบัญชีที่มีระดับสิทธิ์สูง

Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Discovery	T1069.002	Permission Groups Discovery
Initial Access	T1078	Valid Accounts
	T1078.002	Use of Valid Accounts
Privilege Escalation	T1548	Abuse Elevation Control Mechanism
	T1484.002	Domain Trust Modification
Persistence	T1556.001	Modify Authentication Process
Credential Access	T1558.003	Kerberos Tickets

Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

Event Log

ตรวจสอบ Event log ว่ามีการบันทึกร่องรอย Event ID ตามด้านใต้นี้ในลักษณะที่ผิดปกติหรือไม่

Event ID 4662 อีเวนท์นี้เกี่ยวข้องกับการเรียกอ่าน attribute ของ OU, msDS-ManagedServiceAccount, หรือการ query object class

Event ID 5137 การสร้าง object ใหม่ใน OU (objectClass = msDS -ManagedServiceAccount) โดยบัญชีที่ไม่ใช่ admin

Event ID 5136 มีการแก้ไข attribute msDS-ManagedAccountPrecededByLink หรือ msDS-GroupMSAMembership

Event ID 2946 การสร้าง Tickget Granting Ticket สำหรับ dMSA

แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

- เฝ้าระวังการสร้าง dMSA: แนะนำให้ตั้งค่า **SACL (System Access Control List)** เพื่อบันทึกเหตุการณ์ที่เกี่ยวข้องกับการสร้าง dMSA โดยเฉพาะอย่างยิ่งเมื่อเกิดจากบัญชีผู้ใช้ที่ไม่ได้มีหน้าที่ดูแลระบบตามปกติ
- ติดตามการแก้ไขการ Attribute: ตั้งค่า SACL เพื่อบันทึกกิจกรรมการแก้ไขค่า **msDS-ManagedAccountPrecededByLink** ซึ่งอาจเป็นสัญญาณของการพยายามเชื่อมโยงบัญชี dMSA กับบัญชีที่มีสิทธิ์สูงกว่า
- ตรวจสอบการออก Kerberos Ticket สำหรับ dMSA: ควรตรวจสอบการออก Ticket โดยเฉพาะที่มีลักษณะของ KERB-DMSA-KEY-PACKAGE ซึ่งอาจบ่งชี้ถึงความพยายามในการใช้ช่องโหว่เพื่อยกระดับสิทธิ์

การป้องกัน (Prevention)

- ตรวจสอบเวอร์ชันของ Windows Server: ควรตรวจสอบให้แน่ใจว่าเครื่องแม่ข่าย Windows Server ได้รับการอัปเดตแพตช์ความปลอดภัยล่าสุด โดยเฉพาะแพตช์ที่เกี่ยวข้องกับช่องโหว่ dMSA Privilege Escalation (CVE-2025-53779) เพื่อป้องกันไม่ให้ถูกโจมตีผ่านช่องทางนี้
- จำกัดสิทธิ์ Delegation บน Organization Unit : ยกเลิกสิทธิ์ Create Child Objects, WriteProperty เกี่ยวกับ msDS-* สำหรับผู้ใช้หรือกลุ่มที่ไม่จำเป็นต้องมีสิทธิ์ดังกล่าว
- เปิดใช้งาน MFA: พิจารณาบังคับใช้ MFA สำหรับบัญชีผู้ใช้ที่มีสิทธิ์ในการจัดการ OU หรือ Active Directory เพื่อช่วยลดความเสี่ยงจากการถูกขโมยบัญชีหรือรหัสผ่าน

การรับมือ (Response)

- แยกอุปกรณ์ที่ติดเชื้อ: หากตรวจพบการบุกรุก ให้รีบทำการตัดการเชื่อมต่อ Domain Controller หรือ Host ที่ถูกใช้ในการสร้าง dMSA
- ยกเลิกการใช้งาน dMSA object ที่น่าสงสัย: แนะนำให้ปิดการใช้งาน (disable) หรือระงับการทำงานของ dMSA object ที่อาจถูกสร้างขึ้นโดยผู้ไม่หวังดี เพื่อป้องกันการนำไปใช้ต่อในขั้นตอนการโจมตีอื่น ๆ

- เพิกถอน Kerberos Tickets ที่ออกโดยไม่ได้รับอนุญาต: ดำเนินการบังคับให้ผู้ใช้ทำการ logoff หรือรีสตาร์ท KDC service เพื่อให้ Kerberos tickets หมดอายุ ซึ่งจะช่วยตัดสิทธิ์การเข้าถึงของผู้โจมตีที่อาจถือครอง ticket อยู่
- เก็บหลักฐานทางดิจิทัล: รักษาสภาพของเครื่องที่ติดเชื้อไว้เพื่อการวิเคราะห์หาสาเหตุและสืบสวน (Digital Forensics)
- กู้คืนระบบ: กู้คืนระบบจากไฟล์ Backup ที่มีความปลอดภัย และได้รับการอัปเดตแพทช์ พร้อมทั้งทำการเปลี่ยนรหัสผ่านของ Admin และ Service Accounts ที่เกี่ยวข้องทั้งหมด ป้องกันการเข้าถึงซ้ำ
- รายงานเหตุการณ์: แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์

อ้างอิง (References)

1. National Vulnerability Database
   https://nvd.nist.gov/vuln/detail/CVE-2025-53779
2. Akamai blog "BadSuccessor: Abusing dMSA to Escalate Privileges in Active Directory"
   https://www.akamai.com/blog/security-research/abusing-dmsa-for-privilege-escalation-in-active-directory?

แบบประเมินรายงานข่าวกรองไซเบอร์

https://dg.th/nsexlfob51

จัดทำโดย

ฤทธิ์นภา ประเสริฐศรี

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน
ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ
โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th